



GROUP 28 · CSIT321

System Functionality

Certacito.ai · A4 Prototype Presentation appendix

Project Certacito.ai, AI agent governance platform

Document functionality.md

Date 07 August 2026

Live system <http://20.92.93.30>

A4 appendix. What the system does today and how each kind of user is expected to interact with it. FR numbers refer to the RTM ([docs/requirements-traceability.md](#)).

1. Actors

ACTOR	HOW THEY TOUCH THE SYSTEM
AI agent	Machine caller. POSTs intended actions to <code>/api/v1/intercept</code> with an <code>X-API-Key</code> before executing them, and obeys the PERMIT/DENY/ESCALATE answer.
Administrator	Full console access: policies, users, agents, approvals, reports.
Analyst	Reviews approvals, reads audit/reports, manages day-to-day governance. Cannot manage users or delete policies.
Viewer	Read-only visibility across dashboard, audit and reports.

2. The core loop (FR-01..FR-06)

1. An agent wants to act (read a dataset, call an API, write files, send email...).
2. The hook/SDK intercepts the action pre-execution and sends it to Certacito.
3. Semantic guard (FR-08) checks content, risk classifier (FR-09) scores it, policy engine (FR-02) matches the rules.
4. **PERMIT** - agent proceeds. **DENY** - agent is blocked. **ESCALATE** (FR-05) - action pauses into the approval queue with an SLA countdown.
5. A human approves or denies from the queue; SLA expiry auto-rejects (fail-closed).
6. Every decision lands in the hash-chained audit log (FR-03) and appears on the dashboard within two seconds (FR-06) via WebSocket push.

3. Expected interaction, screen by screen

Landing page - public. Explains the product, "Log in" enters the console.

Sign-in - email + password (demo: `admin@certacito.ai / test123`). Wrong creds get a generic error; the login endpoint is rate-limited (10/min) against brute force.

Agent Overview - first screen after login. Card per registered agent: status, risk tier, compliance score, violation count. Scan-level view; "View in Registry" jumps to management.

Governance Dashboard - the compliance officer's home. KPI tiles (intercepted, blocked, critical, pending approvals), live activity feed (newest decisions push in via the socket), risk breakdown, 7-day decision trend, top violated rules, quick actions. Clicking a feed item or "View queue" deep-links to the relevant screen.

Audit Log - the evidence screen. Filter by search text, risk, outcome, action type. Click a row to expand the full decision record: PII-masked payload, the entry's SHA-256 chain hash and its predecessor's, and the decision trail. ****Verify chain**** re-walks the whole chain server-side and reports intact/broken with the entry count. Export CSV downloads the filtered view; Export PDF prints it.

Approval Queue - human-in-the-loop. Each pending item shows the agent, the masked payload, the matched rule and a live SLA countdown ("until auto-reject"). Approve/Deny asks for confirmation, is logged permanently and attributes the decision to the signed-in reviewer (from the JWT, not the request).

Policy Rules - DevSecOps home. Rule list with action-type filter chips. Create/edit rules (name, action type, risk threshold, default outcome, conditions, regulatory tag), toggle rules active/disabled (persists via the API), inspect version history. A banner reminds that rules are version-controlled config, not model prompts. Rule changes take effect on the next intercepted action.

Agent Registry - register agents, edit metadata (model, environment, owner), suspend/reactivate instantly. Suspension causes the policy engine to DENY that agent's actions.

Reports & Compliance - per-framework compliance scoring (Privacy Act 1988, ISO 27001, SOC 2, OWASP LLM Top 10, NIST CSF, ASD Essential 8) computed from the audit history, with week-on-week deltas.

Settings - user management (admin only): create users, assign roles.

4. Demo scenario (repeatable)

POST /api/v1/demo/healthcare-scenario replays a scripted GP-office sequence - a permitted read, a denied out-of-scope Medicare record access, and an escalated bulk export - so a full governance story can be told in ~2 minutes without waiting for the simulator. This also stands in for the Group 2 integration (FR-11) until their agent API contract lands.

5. What a user should NOT be able to do (and why we test it)

- A Viewer cannot approve, edit policies or create users (RBAC regression tests).
- Nobody can edit or delete an audit entry through the API - there is no endpoint.
- An agent key cannot call human endpoints, and a JWT-less browser gets 401s.
- Registration is closed: only admins create accounts (first account bootstraps).